DOCUMENTO CONFIDENCIAL
Distribución restringida
RED TEAM · PENETRATION TEST

Informe de Pentesting

Laboratorio «El Archivero» — Explotación de capabilities en Linux

Objetivo	172.17.0.2 (host 842fed768f4c)
Tipo de prueba	Caja negra — acceso en red interna autorizada
Dificultad	Fácil (★☆☆☆☆☆☆☆)
Resultado	Compromiso total — acceso root obtenido
Autor	Josep Sanz
Fecha	26 de octubre de 2026
Plataforma	Wargami_Labs

1. Resumen ejecutivo

Se realizó una prueba de intrusión contra el sistema objetivo `172.17.0.2` del laboratorio «El Archivero». Partiendo de un acceso en red sin credenciales (caja negra), fue posible obtener en primer lugar acceso como usuario sin privilegios y, posteriormente, **control total del sistema (root)**. El tiempo total de la operación fue de **29 minutos**.

La cadena de ataque combinó dos debilidades encadenadas: credenciales expuestas en un registro de acceso web dejado público, y un *Linux capability* peligrosa (`cap_dac_read_search`) asignada al binario `tar`, que permitió leer archivos protegidos del sistema saltándose por completo los permisos de fichero.

2 Vulnerabilidades críticas
1 Hallazgo medio
root Privilegio alcanzado
29′ Tiempo hasta compromiso

Impacto para el negocio

Un atacante con acceso a la red del sistema podría leer cualquier fichero del servidor —incluyendo `/etc/shadow` (hashes de contraseñas), claves privadas y datos de configuración— y a partir de ahí comprometer de forma permanente la máquina y pivotar hacia otros sistemas. El riesgo global se considera **CRÍTICO**.

Resumen de hallazgos

#	Hallazgo	Severidad	Fase
H-01	Registro de acceso (`access.log`) expuesto públicamente con credenciales en texto claro	CRÍTICA	Acceso inicial
H-02	Capability `cap_dac_read_search` asignada a `/usr/bin/tar` (escalada a lectura root)	CRÍTICA	Escalada de privilegios
H-03	Listado de directorios (*directory listing*) habilitado en el servidor web	MEDIA	Reconocimiento
H-04	Reutilización de credenciales entre servicio web y SSH	ALTA	Acceso inicial

2. Alcance, autorización y metodología

Nota de autorización

Todas las acciones descritas en este informe se ejecutaron dentro de un **laboratorio de prácticas aislado y explícitamente autorizado** (plataforma Wargami_Labs). No se atacó ningún sistema de terceros. El ejercicio tiene finalidad formativa y de documentación.

Parámetro	Detalle
IP en alcance	172.17.0.2 (única)
Fuera de alcance	Cualquier otra IP, denegación de servicio, ataques a la infraestructura del host
Técnicas permitidas	Enumeración, explotación, escalada de privilegios
Máquina atacante	Kali Linux 7.1.5 (`kali@kali`)

Metodología

Se siguió un flujo estándar de pentest alineado con MITRE ATT&CK y PTES:

- **Reconocimiento** → escaneo de puertos y servicios (Nmap).
- **Enumeración web** → descubrimiento de contenido (Feroxbuster).
- **Acceso inicial** → recolección de credenciales y acceso por SSH.
- **Escalada de privilegios** → abuso de capability en `tar`.
- **Post-explotación** → captura de evidencias (flags).

3. Desarrollo técnico del ataque

3.1 Fase de reconocimiento — Nmap

Se lanzó un escaneo completo de puertos TCP con detección de versión y scripts por defecto:

```
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló **dos servicios** expuestos:

Puerto	Servicio	Versión
22/tcp	SSH	OpenSSH 10.0p2 (Debian)
80/tcp	HTTP	SimpleHTTPServer 0.6 (Python 3.13.5) — *directory listing*

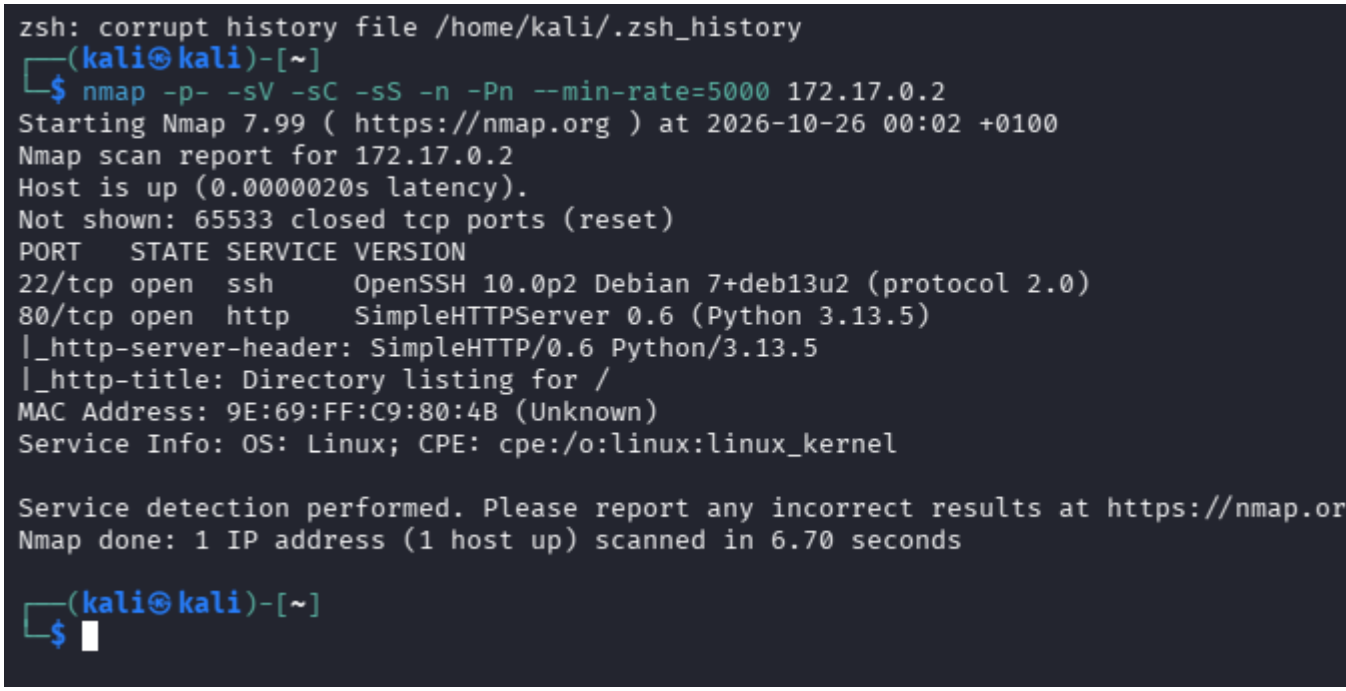


Fig. 1 — Resultado del escaneo Nmap: puertos 22 (SSH) y 80 (HTTP) abiertos.

H-03: El título HTTP «Directory listing for /» indica que el servidor expone el listado de directorios, facilitando el descubrimiento de ficheros sensibles.

3.2 Enumeración web — Feroxbuster

Se enumeró el contenido del servidor web en busca de rutas y ficheros ocultos:

```
$ feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip \
     -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-di
```

Se descubrió el directorio `/logs/` y, dentro de él, el fichero `/logs/access.log` (respuesta HTTP 200), accesible sin autenticación.

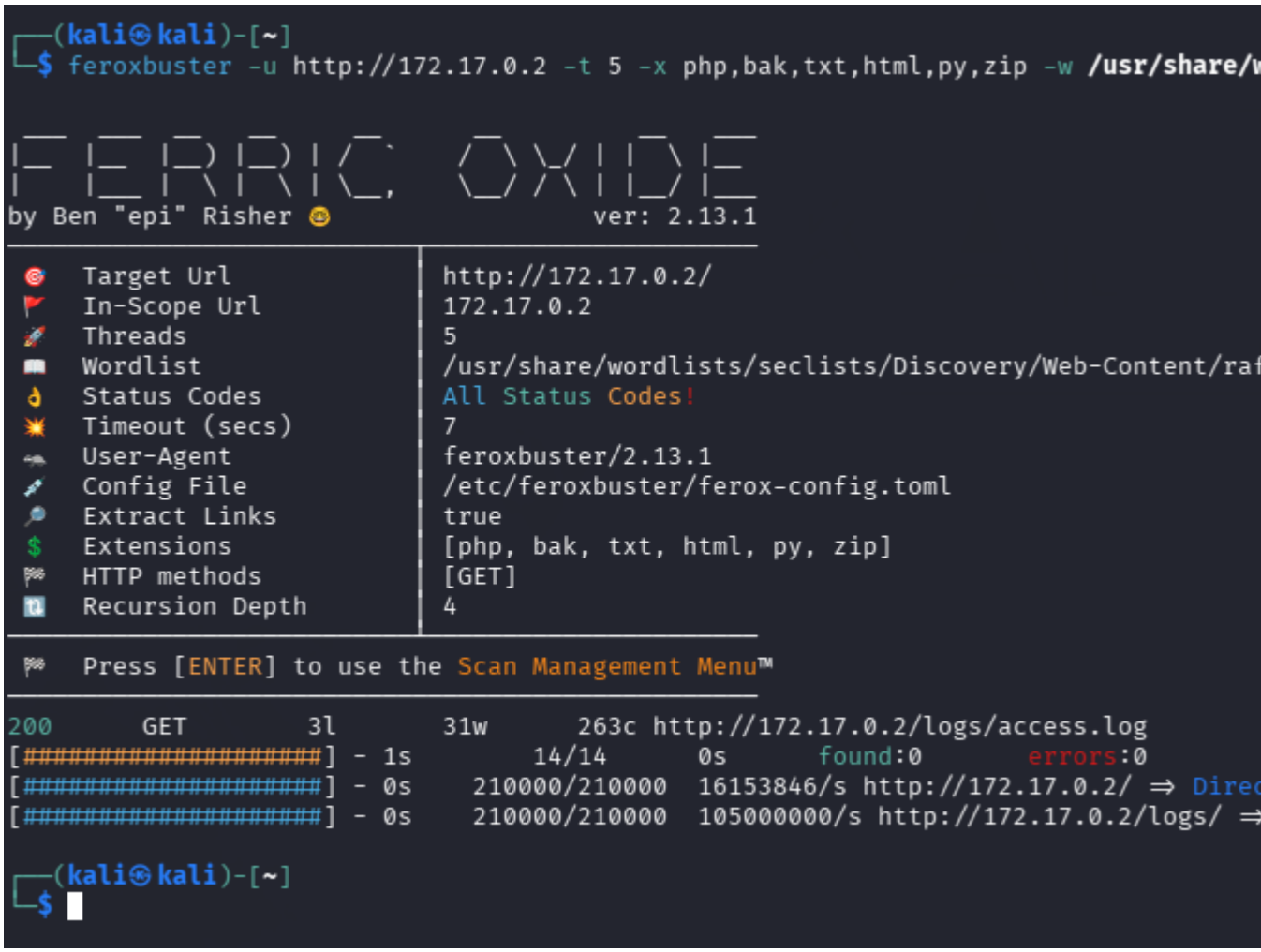


Fig. 2 — Feroxbuster localiza /logs/ y el fichero access.log expuesto.

3.3 Acceso inicial — credenciales en el log

Al descargar y examinar los ficheros recuperados (`access.log`), se encontró una petición `POST /api/auth` que incluía **las credenciales en texto claro** dentro de la cadena de parámetros:

```
172.17.0.1 - - [05/May/2026:10:05:22] "POST /api/auth HTTP/1.1" 401 122 "u
```

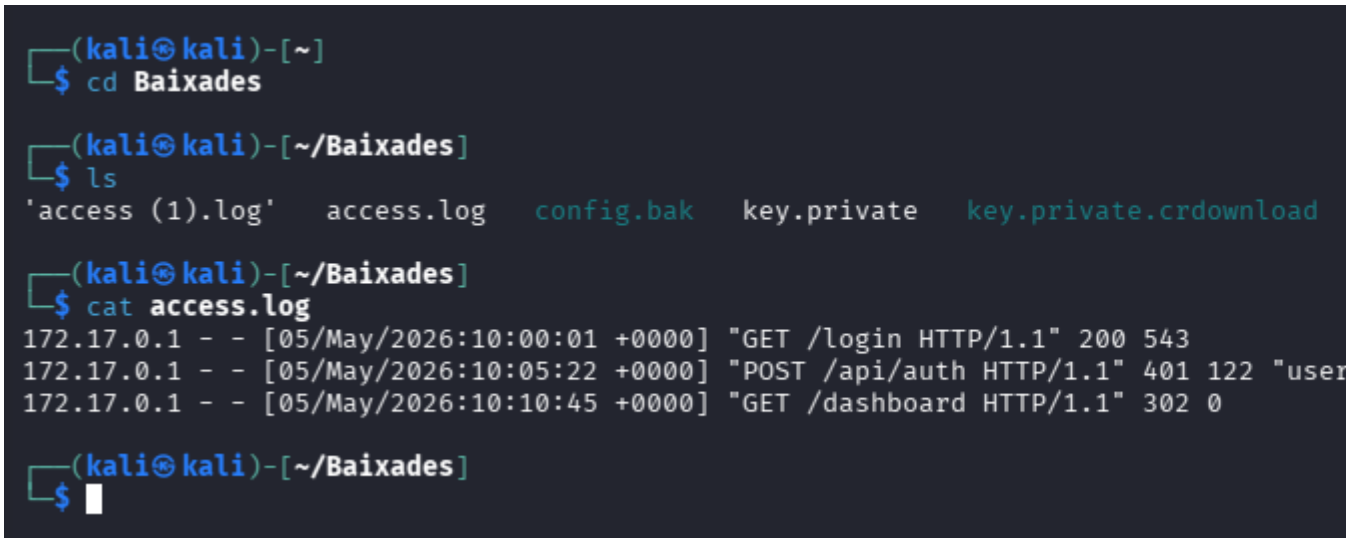


Fig. 3 — Credenciales student / student123 filtradas en el registro de acceso.

H-01: Nunca deben registrarse credenciales en los logs, y mucho menos exponer esos logs públicamente. Esto constituye una filtración directa de secretos.

Las mismas credenciales se reutilizaron con éxito contra el servicio SSH (**H-04**):

```
$ ssh student@172.17.0.2        # contraseña: student123
student@842fed768f4c:~$ id
uid=1000(student) gid=1000(student) groups=1000(student)
```

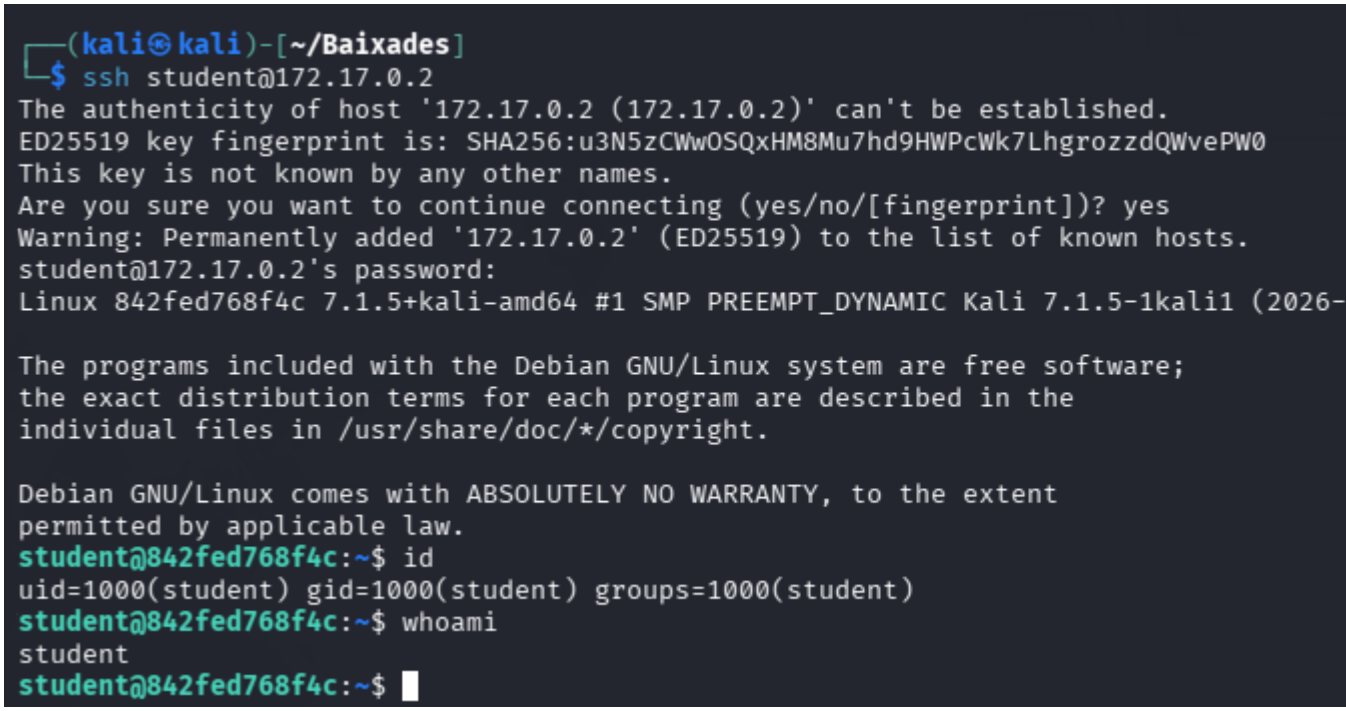


Fig. 4 — Acceso SSH conseguido como usuario «student».

3.4 Captura de la flag de usuario

En el directorio personal del usuario se localizó `user.txt`:

```
$ cat user.txt
Capabilities{e1_archiv3ro_tar}
```



Fig. 5 — Flag de usuario validada. El nombre ya anticipa el vector: «tar».

Flag USUARIO: Capabilities{e1_archiv3ro_tar}

3.5 Escalada de privilegios — capability en `tar`

Durante la enumeración local se revisaron las *capabilities* de Linux asignadas a binarios del sistema. Se encontró que `/usr/bin/tar` tenía asignada `cap_dac_read_search`:

```
$ getcap -r / 2>/dev/null
/usr/bin/tar cap_dac_read_search=ep
```

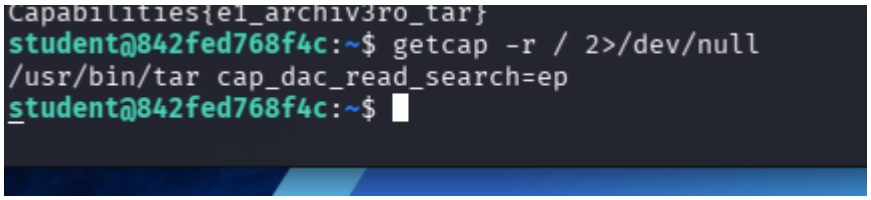


Fig. 6 — getcap revela cap_dac_read_search sobre /usr/bin/tar.

¿Por qué es peligroso?

La capability `cap_dac_read_search` permite **saltarse las comprobaciones de permisos de lectura** de cualquier fichero y directorio del sistema. Aunque no concede escritura ni ejecución como root, sí permite **leer cualquier archivo** —incluidos `/etc/shadow`, `/root/` y claves privadas— pese a que el usuario sea un simple `student`.

El binario `tar` puede empaquetar ficheros que normalmente no serían legibles. Se empaquetó todo el directorio `/root` (protegido) y después se extrajo en una ubicación con permisos de escritura (`/tmp`):

```
$ cd /tmp
$ tar -cvf backuproot.tar /root     # leer /root saltando permisos
$ tar -xvf backuproot.tar            # extraer aquí
$ cat /root/root.txt
cat: /root/root.txt: Permission denied   # acceso directo sigue denegado
$ cat /tmp/root/root.txt             # pero la copia extraída sí se lee
Capabilities{e1_archiv3ro_root}
```

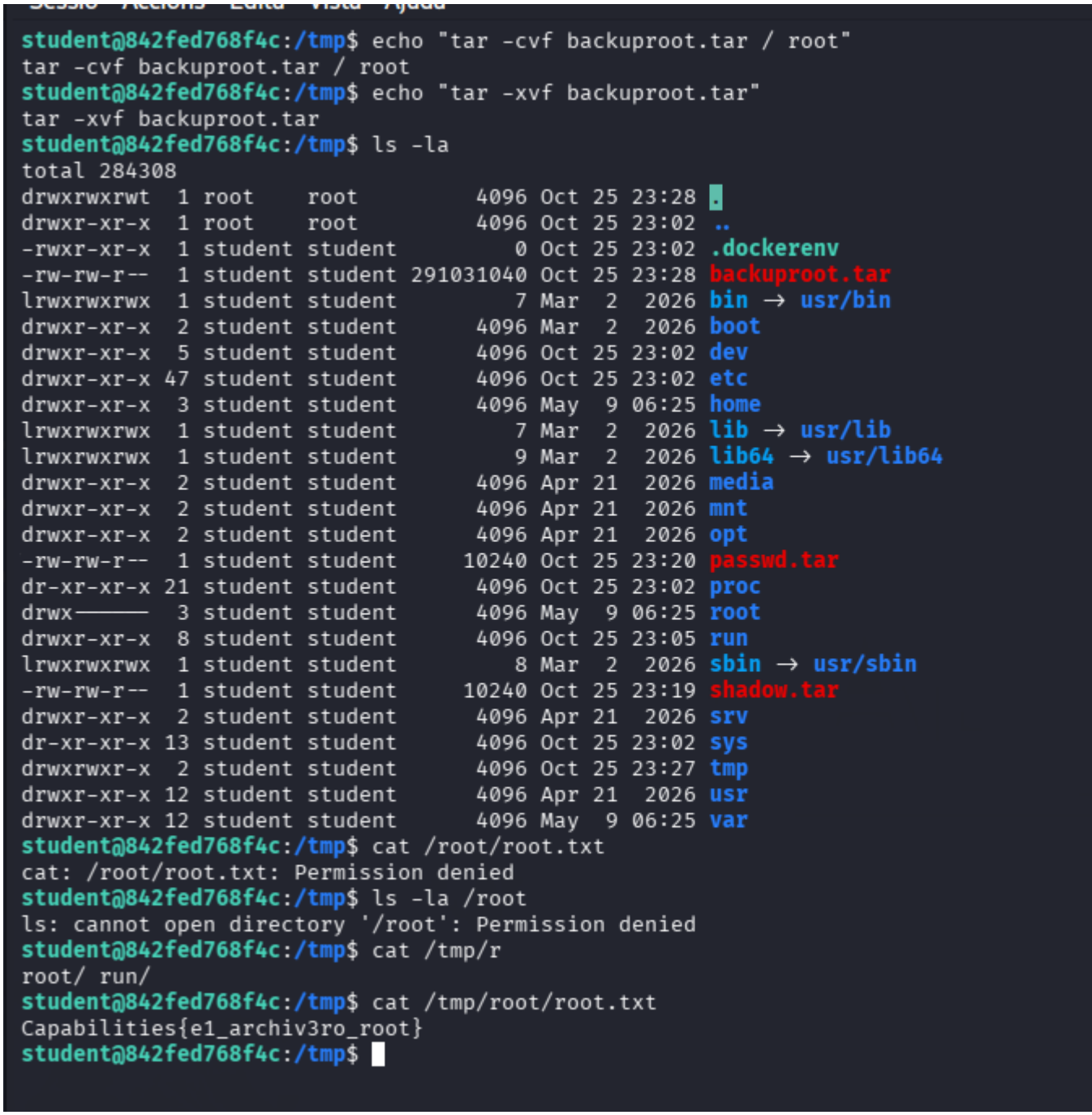


Fig. 7 — Se empaqueta /root con tar y se extrae en /tmp; la copia es legible pese al «Permission denied» directo.

El mismo método permite exfiltrar `/etc/shadow` y `/etc/passwd` (visibles como `shadow.tar` y `passwd.tar` en el listado), de donde se podrían extraer y crackear los hashes de contraseñas de todos los usuarios, incluido root.

3.6 Captura de la flag de root

La lectura de `/tmp/root/root.txt` confirma el compromiso total del sistema:

Flag ROOT: Capabilities{e1_archiv3ro_root}

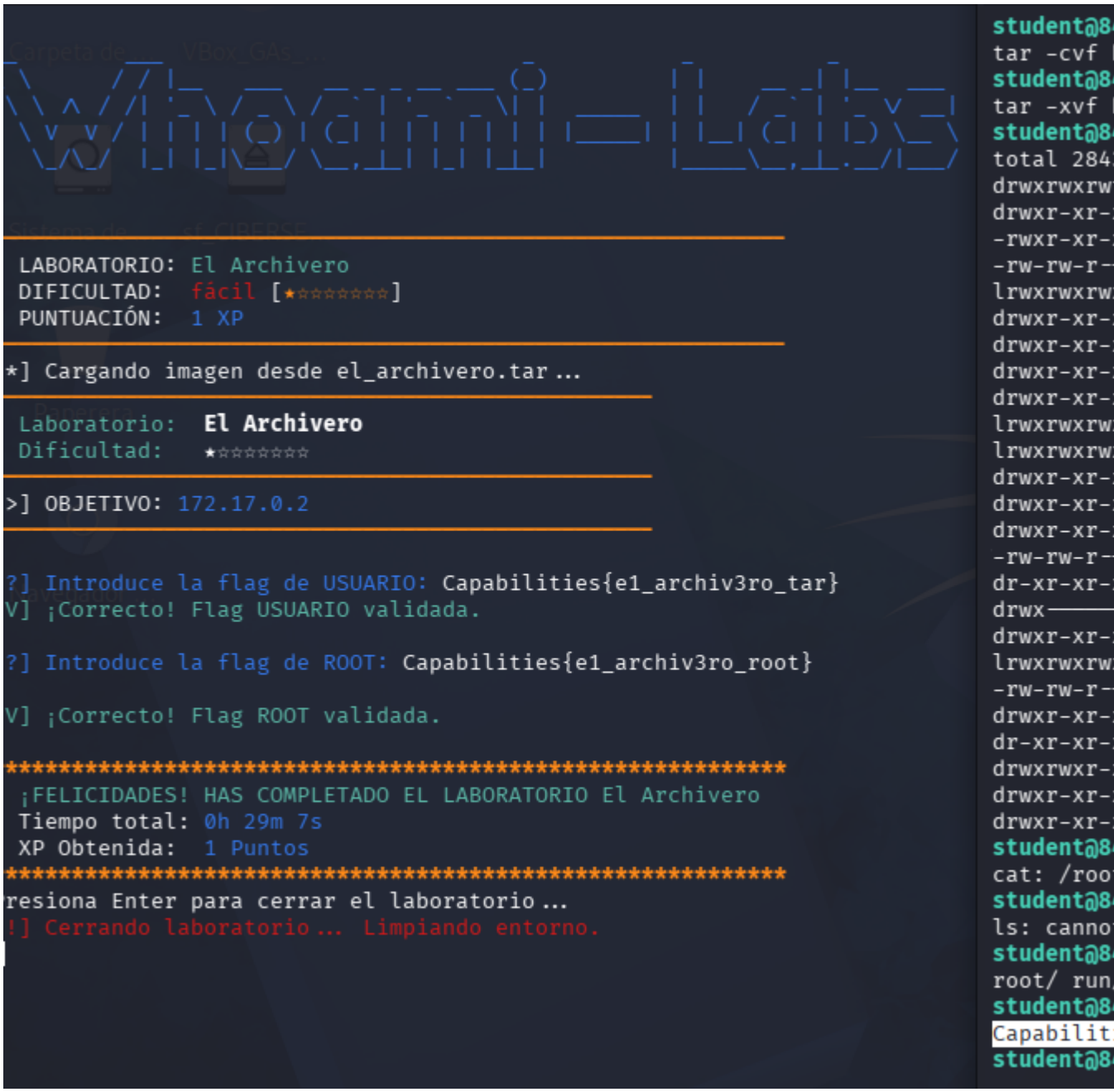


Fig. 8 — Laboratorio completado: ambas flags validadas (usuario y root) en 29 min 7 s.

4. Hallazgos y remediación

H-01 · Credenciales expuestas en log público CRÍTICA

Descripción	El fichero `/logs/access.log` es accesible sin autenticación y contiene credenciales en texto claro (`student:student123`).
Impacto	Acceso inicial directo al sistema por SSH.
Remediación	No registrar credenciales en logs; sanear los parámetros sensibles antes de escribir; retirar los logs del directorio público (`web root`) y restringir su acceso.

H-02 · Capability peligrosa en `tar` CRÍTICA

Descripción	`/usr/bin/tar` tiene `cap_dac_read_search=ep`, permitiendo lectura de cualquier fichero del sistema a usuarios no privilegiados.
Impacto	Lectura de `/etc/shadow`, `/root`, claves privadas → compromiso total.
Remediación	Eliminar la capability con `setcap -r /usr/bin/tar`. No asignar capabilities a binarios de propósito general; si se necesita, usar un binario dedicado con control de acceso estricto.

H-03 · Directory listing habilitado MEDIA

Remediación	Deshabilitar el listado de directorios en el servidor web y servir solo los recursos previstos.

H-04 · Reutilización de credenciales web↔SSH ALTA

Remediación	Usar credenciales distintas por servicio, aplicar política de contraseñas robustas y preferir autenticación SSH por clave con MFA.

5. Conclusión

El sistema «El Archivero» fue comprometido completamente mediante el encadenamiento de una filtración de credenciales y el abuso de una capability mal asignada. Ninguno de los dos fallos requiere explotación sofisticada: ambos son errores de configuración evitables. Corregir **H-01** y **H-02** rompe por completo la cadena de ataque. Se recomienda priorizar esas dos acciones de inmediato.

Resumen de evidencias (flags):
Usuario → Capabilities{e1_archiv3ro_tar} · Root → Capabilities{e1_archiv3ro_root}

— Fin del informe —
Elaborado por Josep Sanz · 26/10/2026 · Documento confidencial.